

EBAE Reference Prototype v0.2 — Audit and Remediation Record

This record maps defects discovered during a second adversarial review pass over the v0.1 code — an internal re-audit, not an external security review — to their v0.2 remediation and regression coverage. Each defect was found outside the original v0.1 test suite; each now has a dedicated regression test that fails against v0.1 behavior and passes against v0.2.

Finding	v0.2 remediation	Regression evidence
Active manifest expiry was checked only when staged	Certifier and executor revalidate the signed manifest and expiration at certification/reservation; release revalidates expiration before SENT	<code>active_manifest_expiry</code>
Staged envelope trusted at activation	Activation recomputes the ACD, verifies quorum/signatures, predecessor, state floor, executor identity, epoch, and expiry inside the activation transaction	<code>staged_manifest_expiry</code> , <code>activation_revalidates_staged_data</code>
Restart lost <code>self._manifest</code>	Constructor reloads the active envelope by protected ACD, verifies it, restores receipts, and catches the anchor up after an interrupted anchor write	<code>restart_restores_active_state</code>
SENT + authoritative ABSENT caused <code>target_digest_conflict</code>	A signed authoritative <code>ABSENT</code> result is mapped to <code>ABORTED</code> during recovery; it never authorizes a retry or effect	<code>sent_but_not_received</code>

SENT was not anchored	PREPARED→SENT increments protected continuity state and advances the external anchor before target invocation	<code>sent_transition_rollback</code>
Negative values passed policy and credited the source	Certifier and target both require a positive non-Boolean integer amount	<code>invalid_amounts</code>
Target identity was a caller-supplied string	Manifest binds executor and target Ed25519 public keys; target requires executor proof of possession; executor verifies signed target responses	<code>executor_proof_of_possession , forged_target_response</code>
Mock target state was volatile and non-transactional	Accounts, operations, transfers, conditions, and idempotency records now commit atomically in SQLite	<code>persistent_target_idempotency</code>
Receipts existed only in memory	Receipts are transactionally stored with the CLOSED transition and reloaded after restart	<code>restart_restores_active_state , idempotent_concurrent_close</code>
Concurrent close could create repeated receipt events	CLOSED is idempotent and returns the single stored receipt; operation ID is the receipt primary key	<code>idempotent_concurrent_close</code>
<code>certificate_id</code> uniqueness did not separately protect nonce reuse	<code>consumed.nonce</code> is independently UNIQUE	<code>nonce_unique_across_certificates</code>
Safe mode could disappear on ordinary restart	Safe state is persistent; new safe-mode transitions also advance continuity when the	<code>forged_target_response</code>

Deliberately bounded areas

The implementation does not claim to authenticate the two human approval tokens, replace the simulated anchor with hardware, handle replicated executors, provide a hardened cross-language encoding, or prove the state machine complete. These remain explicit development tasks rather than hidden assumptions.

Review scope statement

The findings above were produced by structured internal review within the project. No third party has audited this code. When an external review occurs, its findings should be recorded in a separate section of this file with the reviewer identified.